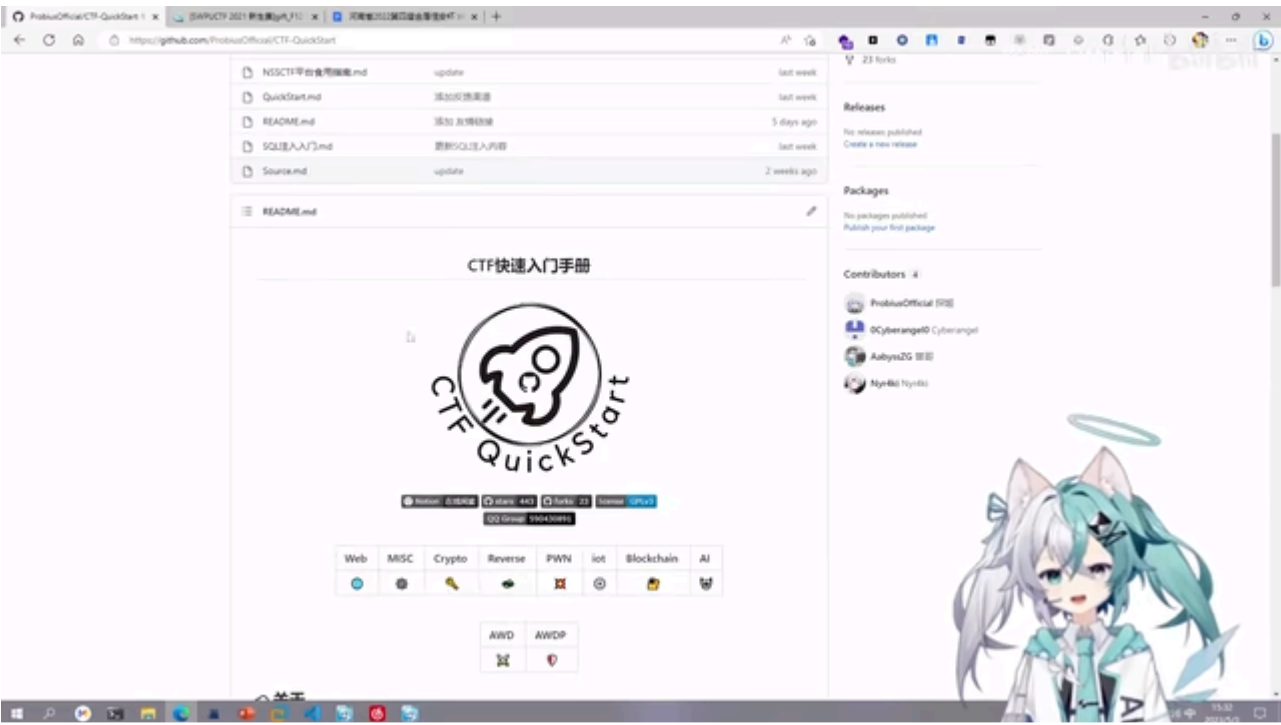


快速开始



❤ 欢迎来到新手村x

注意

在学习CTF前我们希望您具备一些CS领域的基础知识，我们推荐您先阅读 JANlittle师傅写的CS入门资料 ([点此跳转](#)) 大致具备CS领域的基本技能后再开始CTF的学习。

这篇教程会引导你大致的了解CTF，并且尝试教会你如何入门CTF。

当然，文档可能不是那么完善，如果你觉得文档缺少什么东西或者有什么不足的地方，欢迎在下方的评论区留言，我会尽快回复。

在开始之前，我想你可能会有些许疑惑，希望下面的 Q&A 能够帮助到你。

常见问题 Q&A

Q: 什么是CTF

A: 「CTF Capture The Flag」中文一般译作夺旗赛，在网络安全领域中指的是网络安全技术人员之间进行技术竞技的一种比赛形式。CTF起源于1996年DEFCON全球黑客大会，以代替之前黑客们通过相发起真实攻击进行技术比拼的方式；其将安全相关的知识点抽象出来并加入到题目中，我们通过对知识点的理解认知，具体地进行实践来攻克题目。

Q: 什么是Flag?

A: 参赛团队之间通过进行攻防对抗、程序分析等形式，率先从主办方给出的比赛环境中得到一串具有一定格式的字符串或其他内容，并将其提交给主办方，从而夺得分数。为了方便称呼，我们把这样的内容称之为“Flag”。

Q: CTF竞赛模式?

A: CTF有个人赛和团队赛，在主流比赛中多为团队赛；

CTF赛制分多种，国内常见的为「**解题模式 Jeopardy**」「**攻防模式 | AWD (Attack With Defense)**」「**静态攻防 AWDP (Attack With Defence Plus)**」一般分为线上线下两个阶段，线上通常采用**解题模式**，线下通常为**CTF +(理论)+ AWD/AWDP** 模式，具体看主办方安排。

- 「**解题模式 Jeopardy**」目前大多数国内外CTF比赛的主流形式，选手自由组队参赛。题目通常在比赛过程中陆续放出。解出一道题目后，提交题目对应的flag即可得分，比赛结束时分高者获胜。
- 「**攻防模式 | AWD (Attack With Defense)**」通常为现场比赛，多数CTF决赛的比赛形式，选手自由组队参赛。每个队伍都有自己的gamebox，其上运行着一些带有漏洞的服务。参赛战队需要找到漏洞对其他队伍gamebox发起攻击，也需要通过patch服务来加固自己的gamebox。相比于解题模式，时间更短，比赛中更注重临场反应和解题速度，需要能够快速攻击目标主机的权限，考察团队多方面的综合安全能力。
- 「**静态攻防 AWDP (Attack With Defence Plus)**」解题+加固赛，相比AWD赛制取消了gamebox，主办方会根据出题人设置的脚本判断提交的patch是否有效（攻击则和解题模式类似），参赛队伍无法直接攻击其他队伍。每个回合，参赛队伍都会根据自己攻击和加固成功的题目（以及相应题目的解题队伍数）来得分，以累积得分作为排行依据。

? 存有疑惑?

没关系，我们下面还有更迷糊的x 暂时了解就好啦，在CTF中，我们一般接触的最多的就是「**解题模式 Jeopardy**」。

Q: CTF的竞赛方向?

A: 由于CTF知识面很广，一个人不可能面面俱到，所以选手们通常都会选择一个自己喜欢的方向深入研究，，通常分为五个方向:**MISC、CRYPTO、WEB、REVERSE、PWN**：

- 「**杂项 MISC**」安全杂项涉及到古典密码学、编码、隐写术、电子取证、数据分析等广度极高的安全手段及利用方法，选手需要确定手段或者方法，反向的去破译取证从而拿到flag，MISC是CTF比赛中广度最高的方向，需要各个方向都有涉猎。——*嗯？题不知道丢哪？没事丢杂项就好！*
- 「**密码学 CRYPTO**」密码学简单讲就古典密码和现代密码，当然大多数古典密码的题目目前都被划分到MISC中，目前的密码学反而更偏向现代密码学，常出现分组密码、流密码和公钥密码体制的考察，对初等数学、基本的数论有一定需求。选手通常被给予一个加密程序，抹去明文之后留下的加密过程和输出，要求选手通过密码体制的弱点来还原flag。——*听说Oi爷又AK了！*
- 「**网络攻防 WEB**」着重于Web应用程序，框架，浏览器以及各类Web服务器的安全问题；挖掘/利用/研究各类Web系漏洞，探究其形成原理、利用方式及修补方案。题目常见的漏洞类型包括注入、XSS、文件包含、代码执行、上传、SSRF等，选手通过漏洞直接或者间接拿到shell或者得到某些关键文件从而得到Flag。——*汪汪汪*
- 「**逆向工程 Reverse Engineering**」研究各类操作系统，编译器，虚拟机的底层架构，以Windows和Linux为平台，学习可执行程序的逆向分析技术，如软件调试与破解，对已经编译完成的可执行文件进行分析，研究程序的行为和算法，然后以此为依据，计算出出题人想隐藏的flag —— *逆💎💎*

- 「**二进制漏洞利用 Pwn**」Pwn在安全领域是「攻破」的意思。主要研究程序漏洞利用技术，例如栈溢出、堆管理器的漏洞利用和其他高阶技巧；挖掘和分析各类基于编译型语言的漏洞。二进制攻击涉及到栈溢出、堆溢出、格式化字符串漏洞等二进制漏洞，选手需要借助这些漏洞获取计算机权限，从而拿到flag——*PWN!*(指声音)
- **SOMETHING NEW** 随着计算机技术的发展，也有一些新的方向如「**区块链 Blockchain**」「**AI安全**」「**物联网 IoT**」等的加入。这些内容我们会在进阶文档中更新。

Q：我只是个萌新，为什么他们叫我师傅？

A：CTF圈子中，CTFer们通常以"师傅"相互称呼。

Q：什么是WriteUp？

A：又称作WP，是记录CTF比赛中解题过程的文章，通常包含题目描述、解题思路、解题过程、源码分析、脚本分析等内容。当然你也可以简单理解为解题报告——题解。

其他名词解释

- **一把梭** 代指一类解题过程或者方法，一般指将题目中给出的对应的附件 / 代码 / 密文等，直接丢到某个工具或者网站上，就能得到flag的解题方法。
- **套娃** 一是指一些题目比如说加密题，嵌套了多层的加密，需要多次解密才能得到flag，即一道题中可能涉及到多个知识点的考察；二是带有一定贬义意义，通常指出题人只是为了出题而出题，单纯的、一味的、向题目中叠加tricks，导致本来就不新颖的题目还变得更加复杂，使得题目的难度无意义的变高。

Q：学习CTF有什么要求么？

A：信息检索能力 和 学习能力 这两者即可

说人话就是，会用搜索引擎，知道怎么检索信息，知道怎么验证信息正确性，知道怎么在垃圾场里面翻有用信息；然后就是拿到信息之后，快速学习，知道怎么运用知识点。

至少，别人的解题报告(一般我们称之为WriteUp 简称 WP)你得看得懂，你会看着跟着复现。

从哪开始？

✓ 好耶

😏 好了，你已经知道 $1+1=2$ 了，下面来证明一下哥德巴赫猜想吧

? 如何推开CTF的大门

推门啊，手放上去不就行了x?~?

如果你看着五个方向思考良久，一下子不太确定自己的方向，这里提供一些参考，你可以通过下面两个方向先熟悉一下CTF的一些流程，找找——嗯，感觉~

「网络攻防 WEB」

- 在传统的CTF线上比赛中，Web类题目是主要的题型之一。

- 相较于二进制、逆向等类型的题目，参赛者不需掌握系统底层知识；
- 相较于密码学、以及一些杂项问题，不需具特别强的编程能力，故入门较为容易。

「杂项 MISC」

- MISC具有极大的趣味性；
- MISC的入门难度包含维度很广但都很简单，非常适合用来快速熟悉CTF的比赛模式和规则。

⚠ 注意

注意入门方向是为了熟悉CTF比赛模式和规则，并不一定决定你最终方向。在熟悉了CTF大致的形式啊、规则啊什么的之后，就可以自由探索自己喜欢的方向了x

练习平台 & 使用指南

比赛平台

国内目前几大主流平台：(排名不分先后)

NSSCTF <https://www.nssctf.cn/index> (多功能Xenny。适合一人单刷，也适合团队训练。更详细的可以参考 [NSSCTF平台食用指南](#))

BUUCTF <https://buuoj.cn/>

CTFshow <https://ctf.show/> (MISC和Web的入门题单很赞)

攻防世界 <https://adworld.xctf.org.cn/home/index>

青少年CTF <https://www.qsnctf.com/>

CTFhub <https://www.ctfhub.com/#/index> (技能树确实不错，但是更新慢)

Bugku <https://ctf.bugku.com/> (AWD做的比较好)

pwn.college pwn.college (当然如果您一来就相中了PWN的话，这个平台也是不错的选择)

🔗 探姬の唠叨

目前有一个好处就是，基本上每个平台的入门题目，直接搜索就能找到足够详细的WP，只要你会读文档，会跟着复现，并且在这个过程中持续学习，那么入门CTF对你来讲也就不会是什么难事x

如果看到这里，你已经有了大致的想法，那么便可以去尝试一下了~

” 小剧场

"不必等待WP的降临，如果没有WP，我便是WP" —— 鲁迅

"鲁迅说过这话？"

"鲁迅什么话没说过？"

刷题指南

” 小剧场

"凭什么只能指南？你这是方向歧视！""....."

下面我们以NSSCTF为例，简单介绍一下做题流程，和题目类型。

更详细的可以参考 [NSSCTF平台食用指南](#)

The screenshot shows the NSSCTF platform interface. At the top is a navigation bar with the NSS logo and links for 题目 (Challenges), 文章 (Articles), 比赛 (Contests), 排行榜 (Rankings), 动态 (Dynamics), 探索 (Explore), and 团队 (Teams). Below this is a sub-navigation bar for the '题目' section, with links for 讨论区 (8) (Discussion), WriteUp (4), 详细数据 (Detailed Data), 版本 (Versions), and a 返回 (Return) button. The main content area displays the challenge title '[SWPUCTF 2021 新生赛]easyupload1.0'. Below the title, it shows '题目分数: 1' (Challenge Score: 1) and '题目评分: ★ ★ ★ ★ ★ 1.6' (Challenge Rating: 1.6 stars). The '题目标签' (Challenge Tags) section includes 'WEB', 'PHP', and '文件上传' (File Upload). The '题目描述' (Challenge Description) section is currently empty. At the bottom center, there is a button labeled '开启环境👁0' (Open Environment 👁0), which is highlighted with a red rectangular box.

CTF题目开启的基本形式如下：

- 附件 —— 通常为压缩包，每类题型都可能有，可能直接就是题目本身，也可能是题目涉及到的源码等等
- 容器 (常见于Web Pwn，也有可能见于 Misc Crypto ……)
 - Web靶机 —— 通常为 `ip:port / domain:port`

[题目](#)[讨论区 \(8\)](#)[WriteUp \(4\)](#)[详细数据](#)[版本](#)[返回](#)

[SWPUCTF 2021 新生赛]easyupload1.0

题目分数：1

题目评分：★ ★ ★ ★ ★ 1.6

题目标签：[WEB](#) [PHP](#) [文件上传](#)

题目描述：

node1.anna.nssctf.cn:28026

剩余：7198秒

[关闭环境](#)[延长时间](#)

flag

提交

eg: 1.11.45.14:1919 / node3.anna.nssctf.cn:28622

这样的靶机可以直接在浏览器中访问：



- nc 靶机 给出的形式和Web靶机类似：ip:port / domain:port

也有可能没有：ip port / domain port

也有部分靶机给出时会明显带上nc：nc ip port / nc domain port

[题目](#)[讨论区 \(8\)](#)[WriteUp \(6\)](#)[详细数据](#)[版本](#)[返回](#)

[SWPUCTF 2021 新生赛]nc签到

题目分数：1

题目评分：★☆☆☆☆ 0.6

题目标签：[PWN](#) [RCE](#)

题目描述：

node1.anna.nssctf.cn:28845

剩余：7185秒

关闭环境

延长时间

附件下载

flag

提交

这样的靶机不能直接在浏览器中访问，需要使用nc工具连接，通常在Linux系统中接入，或者使用某些工具进行交互，如 `pwntools`

- 当然也有可能附件和靶机都有。比如 Web 涉及到源码审计的时候，也有的nc交互给nc后台的脚本等各种类似的情况

[题目](#)[讨论区 \(0\)](#)[WriteUp \(0\)](#)[详细数据](#)[版本](#)[返回](#)

[羊城杯 2020]a_piece_of_java

题目分数：455

题目评分：☆☆☆☆☆ 0

题目标签：[web](#) [Java](#) [反序列化](#)

题目描述：

node4.anna.nssctf.cn:28806

剩余：7195秒

关闭环境

延长时间

附件下载

flag

提交

新手引导

与其他比赛不同，CTF似乎没有一条能够一镜到底的通路，更多的还是需要探索适合自己的。不过一些基础题单倒是比较确定，可以尝试看看x

下面我们会给出每个方向大致的内容、一些工具和Tricks以及入门路线和基础题单

希望你在入门中 培养 和 强化自己的学习能力，找到属于自己的路。

「杂项 MISC」

前置知识:

知道什么是CTF、知道什么是Flag就行了

基础内容 / 路线:

- OSINT
「开源网络情报 OSINT(Open Source Intelligence)」一种情报搜集手段，从各种公开的信息资源中寻找和获取有价值的情报，一般用于考察选手的信息搜集能力，也有可能考察选手的逻辑推理能力。
- 编码转换 / 古典密码
- 隐写: 图片隐写、音频隐写、视频隐写
- 取证: 流量分析、磁盘取证、内存取证、日志分析取证

入门需要的工具和Tricks

 **Warning**

该部分只提供基础工具,更多工具可以到环境配置章节中的[工具合集](#)查看，在遇到对应题目的时候可在合集中自行查找，到一定程度之后可以尝试自己复现轮子。

项目名称	Usage	项目地址	文档
Python	MISC方向中用途最广的语言。	官网	/
CyberChef	近乎全能的编码解码工具。	官网 国内中文镜像站	/
010 Editor	专业的文本编辑器和16进制编辑器，可通过加载模块脚本，解析文件结构。	官网	/
QR Research	专业的二维码扫描识别软件，支持多个纠错等级，掩码选项(已停止维护)。	/	/
Stegsolve	图像分析工具。	GitHub	/
Wireshark	流量分析取证软件。	官网	/

方便快捷获得题感的一把梭工具：

- [随波逐流工作室 随波逐流CTF编码工具 \(1o1o.xyz\)](#) [随波逐流一把梭](#)
- <https://www.bilibili.com/video/BV1ho4y1s7UG> [PuzzleSolver一把梭](#)

⚠ 给MISC选手的忠告

MISC是一个对编程能力要求比较高的方向，不过大多数考点的固定衍生出比较多的"轮子"，当然轮子减少手动操作，确实是好东西，但是容易产生一些弊端，因为跳过了手动操作所以不懂原理也能梭题目，可能会导致选手略过本来应该学的原理，手动会做之后再碰到了用工具减少操作是完全没问题的，即便没有这些整合工具，用现成脚本说到底本质也是一样的。

📋 题目清单

- [CTFshow](#) 菜狗杯的MISC部分 配合WP 食用 [菜狗杯WriteUP](#)
- CTFshow MISC入门
- BUUCTF MISC部分

当然其他平台也行，注意你的目的是 **学到东西**，而不是看刷题数量

「网络攻防 WEB」

前置知识: 看懂网页就行

基础内容 / 路线: 考点基本围绕几大类型的漏洞：

泄露 | 注入 | 序列化&反序列化 | 文件包含 | 文件上传 | 命令执行 | XSS | SSRF | 逃逸

如果你想了解更多或者前沿，可以参考「**开放式Web应用程序安全项目 OWASP(Open Web Application Security Project)**」计划

Web方向涉及的技术栈以及大致认知路线: JS(JavaScript) → PHP(语言基础,语言特性) → **PHP框架**(例如ThinkPHP) → **Python Java** → **Web框架** 例如Flask(Python) Springboot(Java) Node.js(JavaScript)

⚠ 注意

与开发不同，您无需完整掌握语言再去做题，在了解语言基础后，要做的就是通过题目去学习语言的特性，例如PHP的弱类型特性，Python的反序列化等等，这样的学习方式会更加高效。

入门需要的工具和Tricks

- 工具

项目名称	Usage	项目地址	使用文档	其他
hackbar	浏览器插件，能够在页面上直接完成 请求/响应内容编辑，完成各种包括但是不限于伪造的工作。	谷歌商店 GitHub	/	/
Proxy SwitchyOmega	代理管理软件，方便一个浏览器多个代理端口的切换。	GitHub	/	/
Wappalyzer	页面技术识别软件，方便快速定位页面的框架技术等信息	官网	/	/

项目名称	Usage	项目地址	使用文档	其他
Burp Suite	代理抓包软件，用于Web应用程序的渗透测试和攻击	官网	/	/
Antsword	开源Webshell管理工具	GitHub	/	/
dirsearch	目录扫描工具	GitHub	/	/
SQLMap	自动化的SQL注入利用工具	GitHub	/	/

稍微进阶一点，你可能需要一些 **Linux 基础** —— 因为服务器主流系统都是Linux家族，大多数web服务也都挂载在Linux上面

同时 CTF 中所用的容器也是基于 Linux

有些题目 / 漏洞 涉及到的 RCE 也依赖于Linux命令

同时，你可能需要会简单的使用Docker，用于本地环境的搭建，便于漏洞复现或者本地调试。

Web 入门不会太难，但是和MISC一样，Web 是一个维度很广的方向，所以你需要在做题过程中不断地学习、不断的去了解 Web 这一个庞大的世界。

 **题目清单**

[CTFshow](#) 菜狗杯的Web部分(选做即可 不要死磕) 配合WP 食用 [菜狗杯WriteUP](#)

[CTFshow](#) Web入门

[NSSCTF](#) Web题目 前期建议结合WP 和 tag刷题

[BUUCTF](#) / [QsnCTF](#) 几大经典靶场 —— [Upload-Labs](#) [sqli-labs](#) [PikaChu](#) [Web-DVWA](#) [XSS-Lab](#)……

「密码学 CRYPTO」

前面有说到，密码学主要是两个大类：**古典密码学** 和 **现代密码学**

目前比赛古典密码学多在MISC中考察，如果有涉及到密码学方向的古典密码学，那可能多半是变式 —— 即在古典密码原有的基础或者基于古典密码 置换 和 代换 基本原理创造出的新密码

而绝大部分密码学考察都为现代密码

古典密码参考：

类型	细节
编码	■ ASCII/URL/Unicode/GBK编码 ■ Base/Xxencode/Uuencode编码 ■ Escape/摩斯/HTML实体/敲击编码
移位密码	■ 栅栏密码 ■ 曲路密码
替换密码	■ 凯撒/Atbash/ROT/简单换位/猪圈密码 ■ 夏多/希尔/普莱菲尔/维吉尼亚/自动密钥/仿射密码 ■ 跳舞的小人/键盘/培根密码
混淆	■ ppendcode/rrencode/jjencode/aaencode ■ JsFu*k/jother/brainfuck/whitespace

密码学入门主要以现代密码学为主。

※ 入门需要的工具和Tricks

Python3环境

做题会遇到对应的模組，目前都能搜索到相关教程

【AD / 付费】 推荐 NSSCTF 平台上面 Xenny 老师 工坊密码学系列教程

Crypto系列——格密码

xenny

Crypto 格介绍 格密码 更新中

本工坊为密码学系列格密码。本期由向量开始讲起，带你一步一步了解格密码，以及如何将问题归约到格上求解。带你掌握格密码原理以及各类CTF中格相关密码题目。

2999

2023-06-15

Crypto系列——DSA

xenny

视频课 Crypto 非对称密码 DSA 已完结

* 本工坊为密码学系列DSA课程，本期主要内容为关于非对称加密中的DSA原理和攻击讲解。带你掌握各类CTF比赛中的各类DSA密码题型。

2180

2023-06-09

Crypto系列——分组密码

xenny

视频课 Crypto 对称密码 分组密码 已完结

本工坊为密码学系列分组密码课程，本期主要内容为关于对称加密中的分组模式原理和漏洞讲解。带你掌握各类CTF比赛中的各类分组密码题型。

2580

2023-05-26

Crypto系列——RSA（四）

xenny

Crypto RSA CopperSmith 已完结

本工坊为密码学RSA系列第四期，本次主要内容为CopperSmith相关攻击算法，共11道CTF密码学RSA题目带你学习RSA进阶攻击手段。

2480

2023-05-23

Crypto系列——LCG

xenny

Crypto 流密码 LCG 已完结

本工坊包含7道CTF密码学中流密码LCG题目，包含CTF流密码中的LCG各类攻击原理及其变种应用。

1780

2023-05-21

Crypto系列——RSA（三）

xenny

官方工坊 Crypto RSA 已完结

本工坊包含12道CTF密码学RSA题目，包含CTF中的RSA各类攻击原理及其应用。

2480

2023-05-15

※ 题目尝试：

- NSS 密码学的题目部分
- BUU 密码学部分

注意结合Wp时，因为现代密码学需要一定的数论基础，请不要为了解题而解题，在一些情况下你需要自行完成数学推导，最好是在完成数学推导后通过推导自行编写程序完成题目。

「逆向工程 Reverse Engineering」

目前，CTF中的逆向工程题目形式多数为：用户输入字符串→程序进行check。该过程会进行一系列的校验过程或者说算法，通常能通过校验的字符串便是flag。

所以针对校验过程，有可能是现有的一些加密解密算法，也有可能是出题人自研x

当然，也有许多“游戏性质的题目”，比如迷宫x

下面是你需要了解的东西；

- 可执行文件
- C/C++ 基础
 - “不要学会了基础才去学基础能做什么” 在你掌握了大部分内容就可以开始实践了，这时候打开你的OD 就可以开始对程序进行分析了，我们鼓励在实践中学习
- 汇编语言基础
 - 寄存器、内存、寻址
 - x86/x64 汇编
 - 反汇编、反汇编算法
 - 调用约定
 - 变量、区分处理局部变量

※ 入门需要的工具和Tricks

- IDA Pro (注意：这里尽量选择高版本的，而且不要追求汉化)
- OllyDbg, x64dbg
- GUN Binary Utilities
- GDB 调试器

※ 题目尝试：

- [NSSCTF](#) 中 [HNCTF2022](#) 请前往题库中选中Re标签搜索HNCTF

刷题时可配合 [WriteUp](#) 食用 [HNCTF REVERSE Writeup - 飞书云文档 \(feishu.cn\)](#)

NSS 题目 文章 比赛 排行榜 动态 探索 团队

类型: ALL WEB PWN **REVERSE** CRYPTO MISC MOBILE ETH IOT AI 实战

题单 状态 年份 HNCTF 展开高级搜索选项 随机一题

ID	标题	标签	分数	综合评分
2956	[HNCTF 2022 WEEK2]e@sy_flower	RE 花指令	306	★★★★★
2904	[HNCTF 2022 Week1]X0r	RE xor IDA	357	★★★★★
2902	[HNCTF 2022 Week1]超级签到	RE IDA 交叉引用	360	★★★★★
2903	[HNCTF 2022 Week1]贝斯是什么乐器啊?	RE base64 算法识别	366	★★★★★
2906	[HNCTF 2022 Week1]你知道什么是Py嘛?	RE 算法逆向 xor	387	★★★★★
2908	[HNCTF 2022 Week1]CrackMe	RE Ollydbg	415	★★★★★
3030	[HNCTF 2022 WEEK3]Double	RE 双进程	415	★★★★★
2957	[HNCTF 2022 WEEK2]TTTTTTTTTea	RE TEA	423	★★★★★
2976	[HNCTF 2022 WEEK2]getflag	RE MFC 动态调试	427	★★★★★
2905	[HNCTF 2022 Week1]给阿姨倒一杯Jvav	RE java	439	★★★★★
2907	[HNCTF 2022 Week1]Little Endian	RE 数据存储	439	★★★★★
2958	[HNCTF 2022 WEEK2]来解个方程?	RE Z3	439	★★★★★
2954	[HNCTF 2022 WEEK2]Easy_Android	RE 安卓逆向 代码分析	451	★★★★★
2955	[HNCTF 2022 WEEK2]Try2Bebug_Plus	RE 动态调试 ELF	459	★★★★★
3106	[HNCTF 2022 WEEK4]checker	RE 前端JS逆向	459	★★★★★

- 然后可以尝试NSS其他逆向题目
- 也可以是BUUCTF对应逆向板块的题目

※ 友情链接: [吾爱破解](#) - [LCG](#) - [LSG](#)|[安卓破解](#)|[病毒分析](#)|[www.52pojie.cn](#)

「二进制漏洞利用 Pwn」

【不是AD】强烈推荐 [Cyberangel师傅](#) 的glibc PWN、IoT、angr等文档系列，直接带你从入门到精通!!!

PWN主要考察栈溢出、堆溢出、格式化字符串漏洞等常规的二进制漏洞，选手需要借助这些漏洞获取计算机权限，从而拿到flag。

之前也介绍过PWN靶机，一般后台为 C/CPP 所写的交互程序，我们常用nc连接，或者使用pwntools工具来建立远程连接。

那么你会遇到什么？

- 栈溢出Ret2xxx系列各种ROP
- 格式化字符串

- 堆的各种漏洞
- IO文件劫持和利用
- 整数溢出、type溢出
-

听不懂没关系，这里只是稍微介绍下x 入门之后遇到了自然就懂了喵~ 🐱

这里要强调的是！PWN是一门极其需要耐心的方向，入门的周期也比较长，而且直白的说：他确实需要一定天赋。

入门你可能会面临和逆向类型差不多的挑战，但你的难度显然会更高：

- 汇编
- C / C++
- 编译原理
- Linux
- python

※ 入门需要的工具和Tricks

- IDA Pro (注意：同样地，这里尽量选择高版本的，而且 **不要追求汉化**)
- OllyDbg, x64dbg
- GDB 调试
- pwntools
- 推荐：Roder师傅的 Pwncli <https://github.com/RoderickChan/pwncli>
- 二进制文件分析工具：radare2、objdump等。

这里稍微推荐一点学习资源x

- [Roder师傅](#) 的PWN训练营系列
- [星盟安全团队](#) 的PWN系列教程
- [芥燃斯基](#) 的无痛入门PWN系列

※ 题目尝试：

- pwn.college
- pwnable.tw
- NSSCTF 中 [HNCTF2022](#) 请前往题库中选中PWN标签搜索HNCTF

刷题时 可配合[WriteUp](#)食用 [HNCTF-PWN - 飞书云文档 \(feishu.cn\)](#)

- NSSCTF 中其他PWN题

※ 友情链接：[看雪论坛-安全社区|安全招聘|bbs.pediy.com \(kanxue.com\)](#)

消除信息差

这里提供一些团队的导航网站，或者其他的一些信息，希望能够帮助到你。

- [CTF站点导航 | 猫捉鱼铃](#)
- [渊龙Sec安全团队导航](#)

上一页



None

下一页

[前言](#)

